Jr.Pen - 2.4. Cyber Kill Chain

Task 1 - Introduction

The term **kill chain** is a military concept related to the structure of an attack. It consists of target identification, decision and order to attack the target, and finally the target destruction.

The Cyber Kill Chain will help you understand and protect against ransomware attacks, security breaches as well as Advanced Persistent Threats (APTs).

By understanding the Kill Chain as a SOC Analyst, Security Researcher, Threat Hunter, or Incident Responder, you will be able to recognize the intrusion attempts and understand the intruder's goals and objectives.

- Reconnaissance
- Weaponization
- Delivery
- Exploitation
- Installation
- Command & Control
- Actions on Objectives

Task 2 - Reconnaissance

Reconnaissance is the research and planning phase of an attack against a system or victim. Adversaries use this phase to gather information about their target to inform their next steps.

OSINT Open source intelligence is often utilized by hackers and red teams to leverage public data while conducting investigations, often using database searches. **A valuable piece of recon is OSINT (Open-Source Intelligence).** With OSINT, adversaries gather insights about their target through publicly available information. Some public sources where OSINT data can be collected from include:

- Search engines
- Print and online media
- Social media accounts
- Online forums and blogs
- Online public record databases
- WHOIS and technical data

Reconnaissance Types

- **Passive Recon:** This involves having no direct interaction with the target. This may include WHOIS lookups, social media scraping, or reviewing breach data.
- **Active Recon:** This involves direct contact with the target with activities such as , port scanning, banner grabbing, or probing for open services.

Email harvesting is the process of obtaining email addresses from public, paid, or free services. An attacker can use email-address harvesting for a phishing attack (a type of social-engineering attack used to steal sensitive data, including login credentials and credit card numbers). The attacker will have a big arsenal of tools available for reconnaissance purposes. Here are some of them:

- theHarvester(opens in new tab): other than gathering emails, this tool is also capable of gathering names, subdomains, IPs, and URLs using multiple public data sources.
- Hunter.io(opens in new tab): this is an email hunting tool that will let you obtain contact information associated with the domain.
- OSINT Framework(opens in new tab): OSINT Framework provides the collection of OSINT tools based on various categories.

Social engineering: Social engineering is an attack technique where attackers manipulate people into revealing information or performing actions that compromise security. Common examples are phishing, spear phishing, and pretexting. The best defense is user awareness, MFA, and strong security processes.

Answer the questions below

> What is the name of the Intel Gathering Tool that is a web-based interface to the common tools and resources for open-source intelligence? OSINT Framework

> What is the definition for the email gathering process during the stage of reconnaissance? email harvesting

Task 3 - Weaponization

Weaponization is the phase where attackers prepare their attack tools by combining exploits and payloads, such as malware or malicious documents, before delivering them to the target. Detecting weaponized files through EDR, sandboxing, and threat intelligence helps prevent attacks.

The dark web is associated with a criminal underbelly of the internet. It remains mysterious to most, but knowledge can help you understand exactly what is out there and know what to do about the threats of the dark web.

Malware is a program or software that is designed to damage, disrupt, or gain unauthorized access to a computer.

Exploits are programs or code that take advantage of the vulnerability or flaw in the application or system.

A **payload** is a malicious code that the attacker runs on the system.

In the Weaponization phase, the attacker can adopt the following tactics:

- Create an infected Microsoft Office document containing a malicious macros or **VBA** (Visual Basic for Applications) scripts.
- Create a malicious payload or a very sophisticated worm, implant it on USB drives, and then distribute them in public.
- Set up Command and Control (C2) infrastructure for executing the commands on the victim's machine or deliver more payloads.
- Infect the victim's host with a backdoor, which would provide a way to access the computer system, and bypass the security mechanisms.
- Tailoring phishing templates or OAuth-consent apps to look legitimate and dupe the victim.

Answer the questions below

> What is the term for automated scripts embedded in Microsoft Office documents that can be used to perform tasks or exploited by attackers for malicious purposes? Macro

Task 4 - Delivery

The **Delivery** phase is when attackers choose how to deliver their malicious payload or malware to the target environment. Common delivery methods include:

- **Phishing Emails :** Attackers send malicious emails containing links or attachments to compromise users. Targeted attacks against specific individuals are known as **spear phishing**.
- **USB Drop Attacks :** Attackers use infected USB devices as a physical delivery method, often placing them in public areas or disguising them as legitimate gifts.
- **Watering Hole Attacks:** Attackers compromise websites frequently visited by a target group to redirect users to malicious content or trigger malware downloads.

Answer the questions below

> What do you call an attack targeting a specific group by infecting their frequently visited website? Watering hole attack

Task 5 - Exploitation

The **Exploitation** phase occurs when the attacker's malicious code is executed on the target system by taking advantage of vulnerabilities.

Common exploitation techniques include:

- **Malicious Macro Execution:** Malware is triggered through documents delivered via phishing emails.
- **Zero-Day Exploits:** Attackers exploit unknown and unpatched vulnerabilities.
- **Known CVEs:** Attackers target publicly known vulnerabilities that have not been patched.

After successful exploitation, attackers may attempt **privilege escalation** or **lateral movement** within the network.

Common indicators of exploitation include:

- Unexpected process execution.
- Unauthorized registry modifications or new services.
- Suspicious command-line activity in system logs.

Answer the questions below

> What is the term for a cyber attack that exploits a software vulnerability that is unknown by software vendors? Zero-day

Task 6 - Installation

The **Installation** phase is when attackers establish **persistence** after gaining access to a system. They install backdoors or modify system settings to maintain access even if the initial compromise is detected or removed. Common persistence techniques include:

- **Web Shells:** Malicious scripts placed on web servers (e.g., PHP, ASP, JSP) that allow attackers to remotely control the system.
- **Backdoors:** Tools such as **Meterpreter** can provide remote access and command execution.
- **Windows Services:** Attackers create or modify services to automatically execute malicious payloads and maintain persistence.
- **Registry Run Keys & Startup Folder:** Malware is configured to run automatically when a user logs in.
- **Timestomping:** Attackers modify file timestamps to hide malicious activity and make files appear legitimate.

Masquerading is a defense evasion technique where an attacker disguises a malicious file, process, user account, or activity to appear as legitimate. The goal is to trick users and security tools into believing the activity is normal.

A **web shell** is a malicious script uploaded to a web server that allows an attacker to remotely execute commands and maintain access to a compromised system through a web interface.

Answer the questions below

> What technique is used to modify file time attributes to hide new or changes to existing files? Timestomping

> What malicious script can be planted by an attacker on the web server to maintain access to the compromised system and enables the web server to be accessed remotely? Web shell

Task 7 - Command & Control

The **Command and Control (C2)** phase occurs when attackers establish communication between a compromised system and an attacker-controlled server. This allows them to remotely control the infected machine, execute commands, and manage further attacks.

Common C2 communication methods include:

- **HTTP/HTTPS:** Attackers use web traffic (ports 80 and 443) to hide malicious communication among normal internet traffic.
- **DNS Tunneling:** Malware uses DNS requests to communicate with an attacker-controlled server, making detection more difficult.
- **IRC:** Previously a common C2 method, but now less used due to improved security detection capabilities.

The infected system often sends regular signals to the C2 server, known as **beaconing**, to maintain communication.

Answer the questions below

> What is the C2 communication where the victim makes regular DNS requests to a DNS server and domain which belong to an attacker. DNS Tunneling

Task 8 - Actions on Objectives (Exfiltration)

After going through six phases of the attack, Megatron can finally achieve his goals, which means taking action on the original objectives. With hands-on keyboard access, the attacker can achieve the following:

- Collect the credentials from users.

- Perform privilege escalation (gaining elevated access like domain administrator access from a workstation by exploiting the misconfiguration).
- Internal reconnaissance (for example, an attacker gets to interact with internal software to find its vulnerabilities).
- Lateral movement through the company's environment.
- Collect and exfiltrate sensitive data.
- Deleting the backups and shadow copies. Shadow Copy is a Microsoft technology that can create backup copies, snapshots of computer files, or volumes.
- Overwrite or corrupt data.

Answer the questions below

> What technology is included in Microsoft Windows that can create backup copies or snapshots of files or volumes on the computer, even when they are in use? Shadow Copy

Task 9 - Practice Analysis

Scenario: *The infamous Target cyber-attack, which led to one of the largest data breaches in history took place on November 27, 2013.*

1. Add each of the 6 items on the list in the correct Kill Chain entry form on the **Static Site** Lab. Note that although the Cyber Kill Chain framework consists of 7 stages, only 6 are relevant to this specific scenario:

- exploit public-facing application - 4
- data from local system - 1
- powershell - 6
- dynamic linker hijacking - 3
- spearphishing attachment - 5
- fallback channels - 2

2. Once you have placed all 6 items, use the **Check answers** button to verify your answers. Any item placed in the wrong Kill Chain stage will be underlined in red, so review those and try repositioning them until all answers are correct.

Answer the questions below

> What is the flag after you complete the static site?
> THM{7HR347_1N73L_12_4w35om3}

Task 10 - Conclusion

The **Cyber Kill Chain** helps organizations improve network defense by understanding the stages of a cyberattack. It was originally designed to protect network perimeters and defend against malware-based attacks.

However, modern attackers use advanced **TTPs (Tactics, Techniques, and Procedures)** and can bypass traditional detection methods by changing indicators such as **file hashes and IP addresses**.

Security solutions now use technologies like **AI and advanced analytics** to detect suspicious behavior and small changes in attack patterns.

The traditional Cyber Kill Chain mainly focuses on **external malware attacks** and **network security**, so it is not effective at detecting **insider threats**.